



تقرير تقييم مخاطر أمن المعلومات

DOCUMENT CLASSIFICATION	Internal / Restricted
DOCUMENT REF	ISMS-DOC-06-3
VERSION	1.0
DATED	2026-09-12
DOCUMENT AUTHOR	عمار المصباحي

ISO/IEC 2

سجل المراجع

الإصدار	التاريخ	معدل المراجعة	ملخص التغييرات
1.0	2026-09-12	عمار المصباحي	الإصدار الأول – تقرير تقييم المخاطر لبنك الأفاق الرقمية

التوزيع

الاسم	المنصب
عبدالله المحيسن	رئيس مجلس الإدارة
نورة القحطاني	الرئيس التنفيذي
سارة الحربي	مديرة أمن المعلومات (CISO)
فهد العتيبي	مدير تقنية المعلومات (CIO)
أحمد الغامدي	مدير المراجعة الداخلية
ليلى الدوسري	مديرة الشؤون القانونية
خالد الشمري	مدير الموارد البشرية

الاعتماد

الاسم	المنصب	التوقيع	التاريخ
عبدالله المحيسن	رئيس مجلس الإدارة		2026-09-12

نورة القحطاني	الرئيس التنفيذي		2026-09-12

المحتوى

الصفحة	العنوان	البند
8	المقدمة	1
9	سياق تقييم المخاطر	2
9	السياق الداخلي والخارجي	2.1
9	النطاق	2.2
10	معايير قبول المخاطر	2.3
11	ملخص نتائج تقييم المخاطر	3
12	تقييم المخاطر القائم على الأصول	3.1
12	تقييم المخاطر القائم على السيناريوهات	3.2
13	الملحق أ: تقييم المخاطر التفصيلي	4

1.1 Introduction (المقدمة)

الغرض من هذا التقرير هو تقديم نتائج تمرين تقييم المخاطر الذي تم إجراؤه من 01-08-2026 إلى 09-2026-12 بالنطاق الموضح أدناه. كان الغرض الرئيسي من التمرين هو تقييم المخاطر التي يتعرض لها بنك الآفاق الرقمية وتحديد أي منها يمكن قبوله وأي منها قد يحتاج إلى اتخاذ إجراءات لمعالجتها.

بمجرد الموافقة على تقرير تقييم المخاطر هذا، سيتم تحديد إجراءات محددة ومناقشتها والاتفاق عليها ثم توثيقها في خطة معالجة المخاطر التي سئدار كجزء من نظام إدارة أمن المعلومات (ISMS).

العملية المستخدمة في تقييم المخاطر هذا موضحة في وثيقة Risk Assessment and Treatment Methodology (ISMS-DOC-06-2) وهي جزء من ISMS.

يصف تقرير تقييم المخاطر هذا:

- سياق ونطاق تقييم المخاطر
- الأصول ضمن النطاق
- التهديدات ونقاط الضعف لتلك الأصول
- مالكو المخاطر
- مستوى المخاطر
- ما إذا كان الخطر موصى به للقبول أو المعالجة
- أولوية المعالجة، إن وجدت
- أسباب القبول، عند الاقتضاء

هذا التقرير هو مدخل لمرحلة معالجة المخاطر في العملية ويجب أن تتم الموافقة عليه من قبل الإدارة العليا قبل المتابعة.

الاسم	ROLE IN ASSESSMENT
عمار المصباحي	Lead risk assessor (المقيّم الرئيسي)
سارة الحربي	Assistant risk assessor (CISO – مساعد المقيّم)
فهد العتيبي	Technical advisor (CIO – مستشار تقني)
أحمد الغامدي	Risk owner coordinator (المراجعة الداخلية)

الاسم	الموقع	المنصب
سارة الحربي	المقر الرئيسي – الرياض	CISO
فهد العتيبي	المقر الرئيسي – الرياض	CIO
أحمد الغامدي	المقر الرئيسي – الرياض	مدير المراجعة الداخلية
ليلى الدوسري	المقر الرئيسي – الرياض	مديرة الشؤون القانونية
خالد الشمري	المقر الرئيسي – الرياض	مدير الموارد البشرية
مدير SOC	المقر	فريق العمليات الأمنية

1.2 Risk assessment context (السياق)

نطاق: جميع الأنظمة المصرفية، التطبيقات، قواعد البيانات، البنية التحتية.

معايير القبول: درجة ≥ 4 مقبولة.

1.3 Internal and external context (الملخص)

كان تقييم المخاطر هذا مطلوباً كجزء من تنفيذ معيار **ISO/IEC 27001** لأمن المعلومات داخل بنك الأفاق الرقمية. تقييم المخاطر جزء رئيسي من المعيار وإنشاء نظام إدارة أمن المعلومات (ISMS).

السياق الداخلي:

- الثقافة التنظيمية: بعض الموظفين القدامى يرون أن إجراءات أمن المعلومات تعيق سرعة العمل (القسم 1.3).
- التنوع الثقافي: مزيج من الموظفين السعوديين والوافدين يتطلب مواد تدريبية متعددة اللغات (القسم 1.3).
- دوران الموظفين: 12% سنوياً في قسم تقنية المعلومات (القسم 1.3).

السياق الخارجي:

- تزايد التهديدات السيبرانية: هجمات الفدية، التصيد، DDoS، سلسلة التوريد (القسم 1.4).
- المتطلبات التنظيمية: ساما، NCA، PDPL، PCI DSS (القسم 5.2).
- توقعات العملاء: حماية كاملة لبياناتهم (القسم 5.2).

تم اتخاذ قرار بتبني معيار **ISO/IEC 27001** والسعي للحصول على الشهادة، بحيث يمكن تقديم ضمان متزايد لعملائنا بأننا نأخذ أمن بياناتهم على محمل الجد وأننا نستخدم نهجاً مقبولاً للقيام بذلك.

1.4 Scope (النطاق)

يتناول هذا التقييم المخاطر التي تهدد:

النوع	الأصول
الأنظمة المصرفية الأساسية	Core Banking, Card Management, Instant Payments
تطبيق "أفاق بلس"	iOS + Android
منصة "أفاق نت"	الخدمات المصرفية عبر الإنترنت
قواعد البيانات	Oracle Database + SQL Server
البنية التحتية	40 خادم فعلي + 200 خادم افتراضي
الأصول البشرية	2,500 موظف
الأصول المادية	25 فرعاً، 75 جهاز صراف، مركز البيانات، مركز جدة

المواقع الجغرافية المشمولة:

- المقر الرئيسي – الرياض
- مركز البيانات الرئيسي – الرياض
- مركز التعافي من الكوارث – جدة
- 25 فرعاً مصرفياً
- 75 جهاز صراف آلي

خارج النطاق:

- إدارة المرافق والخدمات العامة (باستثناء أنظمة التحكم في الوصول)
- بعض وظائف إدارة التسويق (باستثناء بيانات العملاء)

1.5 Risk acceptance criteria (مستوى بقبول الخطر)

يوصى بقبول الخطر إذا استوفى واحداً أو أكثر من المعايير التالية:

المعيار	التفاصيل
درجة الخطر 4 أو أقل	مخاطر منخفضة (Low)
التغيرات المعروفة تعني أن الخطر سيستمر لثلاثة أشهر أو أقل	مخاطر مؤقتة
الفوائد المباشرة أو غير المباشرة المحتملة متفق عليها أكبر من الأثر	مخاطر محسوبة

في كل حالة، سيتم ذكر أسباب التوصية بالقبول.

1.6 [تقييم المخاطر القائم على الأصول]

تم تحديد 15 خطراً في تقييم المخاطر هذا.

قبل المعالجة (Pre-Treatment):

النسبة	العدد	المستوى
73%	11	عالي (HIGH)
27%	4	متوسط (MEDIUM)
0%	0	منخفض (LOW)
100%	15	الإجمالي

بعد المعالجة (Post-Treatment):

النسبة	العدد	المستوى
7%	1	عالي (HIGH)
86%	13	متوسط (MEDIUM)
7%	1	منخفض (LOW)
100%	15	الإجمالي

ملاحظة: انخفض عدد المخاطر العالية من 11 إلى 1 بعد تنفيذ خطط المعالجة.

1.7 [Scenario-based risk assessment:]

المرجع	الاصـل	التـهـديـد	نـوع الخـطـر	مـسـئـول الخـطـر	مـسـتـوى الخـطـر	قـبـول المـخـاطـر	مـلـاحـظـات
1	قاعدة بيانات العملاء	Ransomware	CIA	فهد العتيبي (CIO)	HIGH (20)	Treat	تحسين النسخ الاحتياطي + ترقية Anti-malware
2	أفاق نت	DDoS	A	فهد العتيبي (CIO)	HIGH (12)	Treat	حل توزيع جغرافي + مزود حماية DDoS
3	الموظفون	تصيد احتيالي	CIA	سارة الحربي (CISO)	HIGH (20)	Treat	تدريب متقدم + محاكاة شهرية
4	أجهزة محمولة	فقدان/سرقة	C	فهد العتيبي (CIO)	HIGH (12)	Treat	تطبيق FDE على 100% من الأجهزة
5	شهادة SSL/TLS	انتهاء صلاحية	C	فهد العتيبي (CIO)	HIGH (12)	Treat	نظام آلي لمراقبة الشهادات
6	مجلات HR	وصول غير مصرح	C	خالد الشمري (HR)	HIGH (12)	Treat	مراجعة دورية للصلاحيات
7	أفاق بلس	SQL Injection	CIA	مدير التطوير	HIGH (20)	Treat	Secure Coding + اختبار اختراق
8	أنظمة الشبكة	ثغرات متوسطة	CIA	فهد العتيبي (CIO)	MEDIUM (9)	Treat	جدولة إصلاح الثغرات
9	بيانات الاختبار	تسرب بيانات	C	مدير التطوير	HIGH (16)	Treat	Data Masking + فصل البيانات
10	حسابات المسؤولين	مشاركة كلمات مرور	CIA	فهد العتيبي (CIO)	HIGH (20)	Treat	PAM
11	الموردون	خرق بيانات	CIA	مدير المشتريات	HIGH (12)	Treat	متطلبات أمنية في العقود
12	ثقافة البنك	مقاومة التغيير	CIA	سارة الحربي (CISO)	HIGH (12)	Treat	حملة تغيير ثقافي
13	فريق IT	جوران الموظفين	A	خالد الشمري (HR)	MEDIUM (9)	Treat	توثيق المعرفة + تدريب متقاطع
14	Core Banking	فشل النظام	A	فهد العتيبي (CIO)	MEDIUM (10)	Treat	اختبار دوري لخطة التعافي
15	سلسلة التوريد	هجوم Supply Chain	CIA	مدير المشتريات	HIGH (12)	Treat	مراقبة مستمرة للموردين

Appendix A: Detailed risk assessment

[illegible]